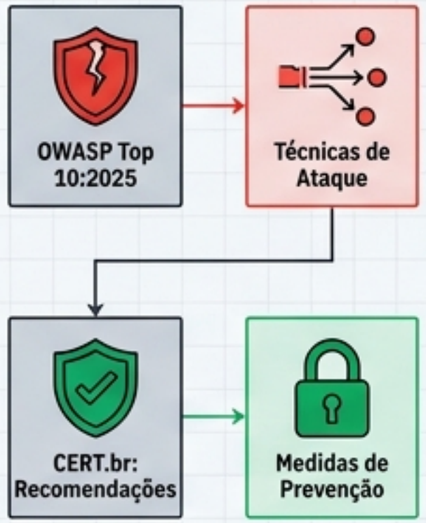
Cibersegurança: Técnicas de Ataques e Exploração de Vulnerabilidades

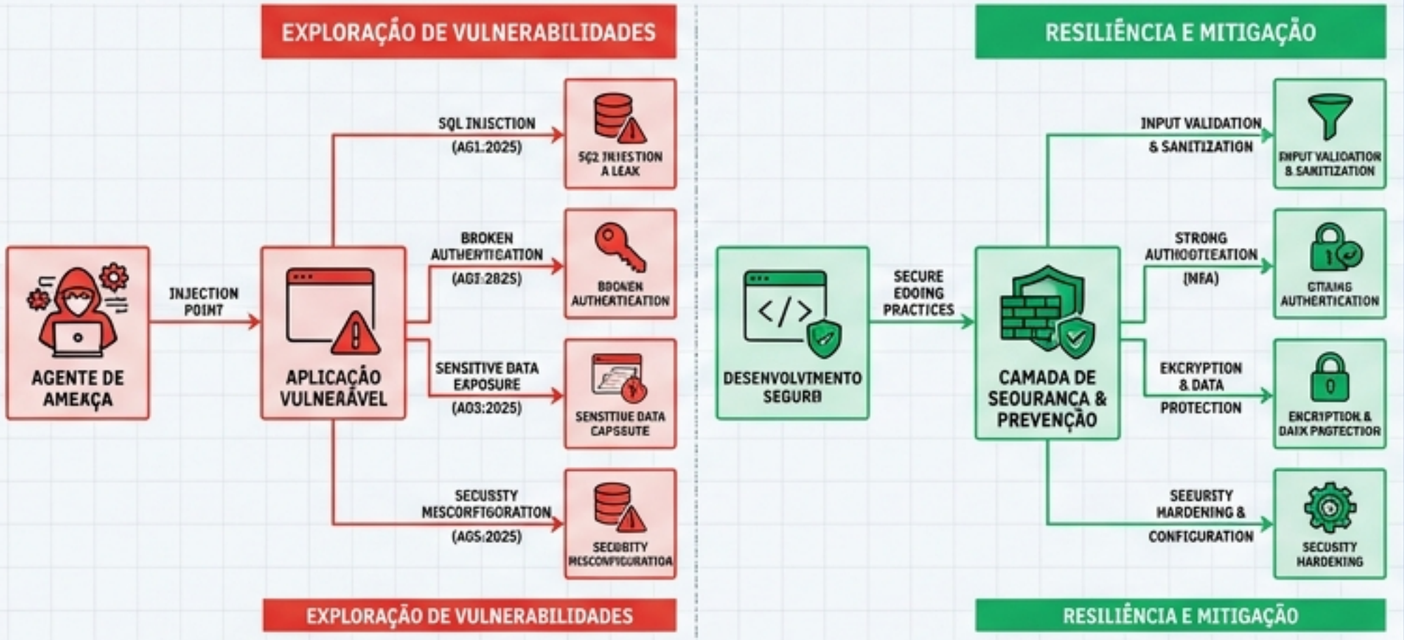
Uma introdução focada em Engenharia de Software, baseada no OWASP Top 10:2025 e recomendações do CERT.br.

VISÃO GERAL DO ECOSSISTEMA (OWASP & CERT.br)



Standard: OWASP Top 10:2025 & CERT.br Best Practices.
Focus: Software Engineering & Secure Development Lifecycle (SDL).

FLUXO DE ATAQUE E DEFESA



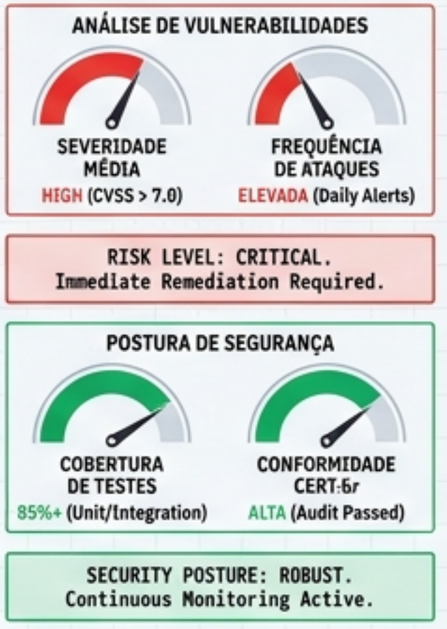
EXPLORAÇÃO DE VULNERABILIDADES

Attack Vectors: Input Validation Failure, Weak Auth, Insecure Config.
Impact: Data Breach, System Compromise, Service Disruption.

RESILIÊNCIA E MITIGAÇÃO

Prevention: Parametrized Queries, Hash & Salt, TLS/SSL, Least Privilege.
Outcome: Risk Reduction, Data Integrity, Availability.

MÉTRICAS DE RISCO E SEGURANÇA



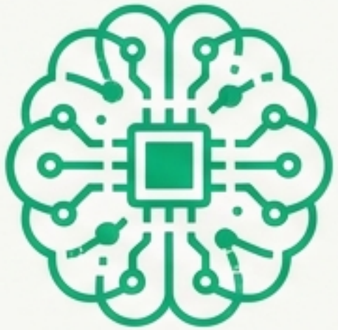
Blueprint Version: v1.0.2
Date: 2024-05-27
Status: APPROVED FOR DEVELOPMENT

Gemini Notebook



Ransomware & Dados

O Ransomware sequestra dados exigindo resgates. Backups atualizados e sistemas resilientes são a última linha de defesa.



Inteligência Artificial

A IA é uma assistente poderosa, mas sistemas não testados podem gerar erros de código e expor dados sensíveis em massa.



Vazamento de Credenciais

Senhas trafegadas em texto claro (como em e-mails) são frequentemente capturadas na rede.

Na internet moderna, a **responsabilidade primária por proteger dados e credenciais** é de quem **constrói e configura o software.**

Gemini Notebook

[Vulnerabilidade]



Uma fraqueza no sistema, como falta de validação no código ou uma configuração padrão esquecida.

[Ator Malicioso]



Uma ameaça que busca agir fora de seus limites, roubar ou destruir.

[Ataque Cibernético]



A exploração bem-sucedida da falha, comprometendo os ativos do sistema.

Gemini Notebook

O Padrão Global: OWASP Top 10:2025

A OWASP (Open Worldwide Application Security Project) publica um documento de amplo consenso com os riscos mais críticos para aplicações web.

Baseado em milhões de testes reais

Guia desenvolvedores para o que realmente importa

- A01: Controle de Acesso Quebrado (Posição #1)
- A02: Configuração Insegura (Posição #2)
- 3 | A03: Conreção Insegura (Posição #3)
- 4 | A04: Habilitação (Posição #4)
- 5 | A05: Injeção (Posição #5)
- 6 | A06: Terrfita (Posição #6)
- 7 | A07: Inreção (Posição #7)
- 8 | A08: Securita (Posição #8)
- 9 | A09: Collceta (Posição #9)
- 10 | A10: Reditado (Posição #10)

Gemini Notebook

A01:2025 — Controle de Acesso Quebrado



100%

Aplicações testadas possuem esta falha.

1.839.701

Ocorrências totais (A campeã absoluta).

20,15%

Taxa Máxima de Incidência.

CLINICAL DEFINICION

Ocorre quando usuários conseguem agir fora de suas permissões pretendidas (ex: contornar verificações alterando URLs, atuar como admin sem login, manipular tokens JWT). Resulta em revelação, modificação ou destruição não autorizada de dados.

Gemini Notebook

A01 na Prática: Mecânica e Defesa

Cenário de Ataque

Mecânica (IDOR): O atacante manipula um identificador diretamente no navegador.

```
URL Original: /app/accountInfo?acct=1234
URL Manipulada: /app/accountInfo?acct=notmyacct
```

Via Terminal (Bypass do Front-end):

```
$ curl https://example.com/app/admin_getappInfo
```

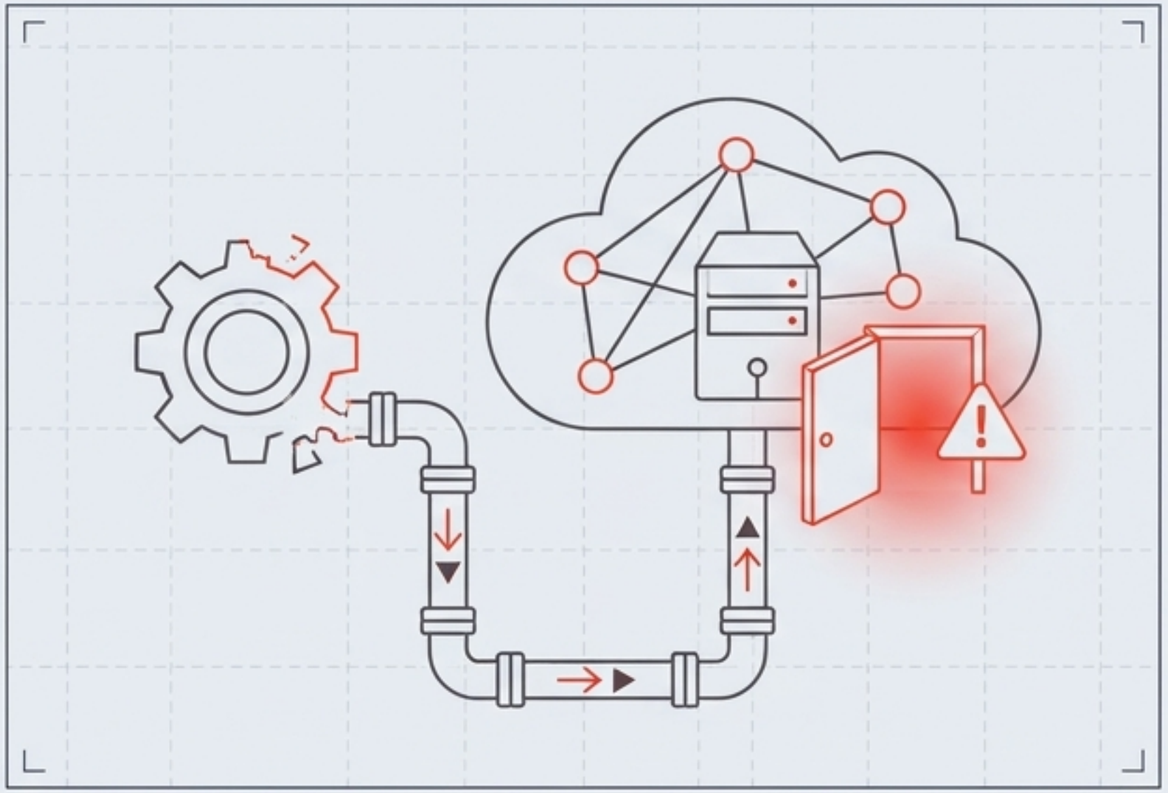
Prevenção (Arquitetura)

Regra de Ouro: Negar por padrão.

- [x] Implementar validação exclusivamente no back-end confiável.
- [x] Invalidar tokens JWT e identificadores de sessão no servidor após o logout.
- [x] Impor limites de negócios diretamente nos modelos de domínio.

Gemini Notebook

A02:2025 — Configuração Insegura



100%

Aplicações apresentam falhas de configuração

> 719.000

Ocorrências reportadas

5ª para 2ª

Posição no ranking
(Devido à nuvem e sistemas complexos)

CLINICAL DEFINITION

A falta de ‘Endurecimento’ (Hardening). Ocorre quando contas padrão não são alteradas, portas ficam expostas, permissões S3 ficam públicas ou mensagens de erro detalhadas revelam os bastidores do sistema.

Gemini Notebook

A02 na Prática: Vazamento de Estrutura

Cenário de Ataque

Passo 1: Atacante acessa a URL raiz e descobre Listagem de Diretórios ativada.

Passo 2: Atacante baixa classes Java compiladas do servidor.

Passo 3: Engenharia reversa revela o código fonte e vulnerabilidades ocultas.

Retorno de Stack Traces: Telas de erro gigantes revelam as versões exatas de componentes vulneráveis instalados.

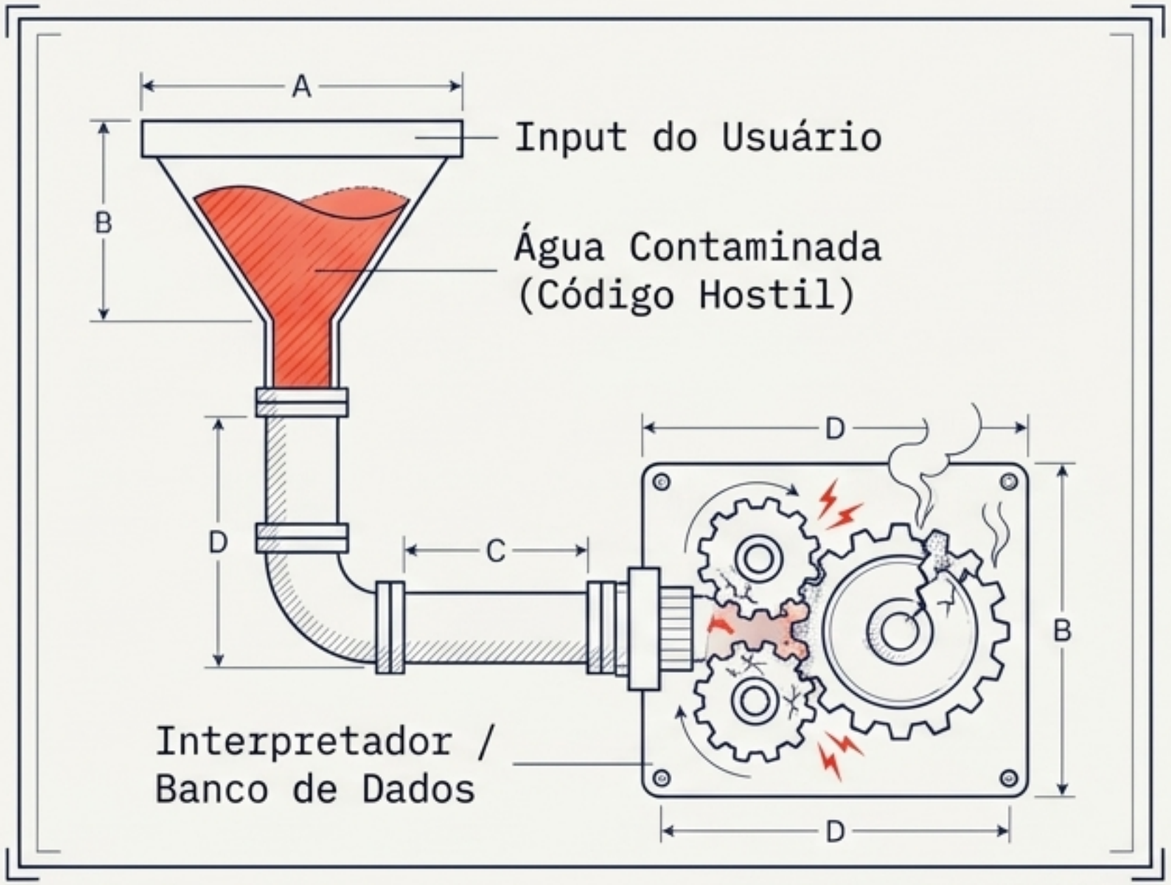
Prevenção (Arquitetura)

Regra de Ouro: Processo de Hardening Automatizado.

- Ambientes de Dev, QA e Produção idênticos com credenciais separadas.
- Uso de uma 'plataforma mínima' (remover componentes que não são utilizados).
- Arquitetura segmentada (conteinerização e ACLs).
- Configuração centralizada para interceptar mensagens de erro brutas.

Gemini Notebook

A05:2025 — Injeção



62.445

Total de CVEs (Maior número absoluto de vulnerabilidades).

> 1.400.000

Ocorrências mapeadas.

CLINICAL DEFINITION

Dados não confiáveis são enviados para um interpretador (SQL, SO, LDAP). O interpretador confunde o dado fornecido pelo usuário com um comando real e o executa.

Gemini Notebook

A05 na Prática: Injeção de Código

Cenário de Ataque

Cenário SQL Clássico:

```
SELECT * FROM accounts
WHERE custID='' OR '1'='1'
```

(Altera a lógica para retornar toda a base de dados).

Cenário de **Sistema Operacional**:

```
String cmd = "nslookup " + domain;
Input do Atacante: example.com; cat
/etc/passwd
```

(Executa comando arbitrário no servidor).

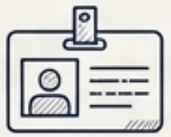
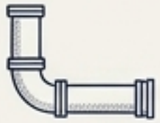
Prevenção (Arquitetura)

Regra de Ouro: Separar dados de comandos.

- ✓ Usar APIs seguras e consultas parametrizadas.
- ✓ Adotar ferramentas modernas de mapeamento objeto-relacional (ORM).
- ✓ Aplicar validação de entrada positiva (allow-list) no servidor.
- ✓ Utilizar escape de caracteres específico do interpretador.

Gemini Notebook

Matriz Diagnóstica: Anatomia das Vulnerabilidades

Vulnerabilidade	Natureza da Falha	Solução Primária
A01: Controle de Acesso 	**Erro** na Lógica de Negócios (Back-end) envolvendo Identidade & Permissão.	**Negar** por padrão e **validar** Tokens.
A02: Configuração Insegura 	**Omissão** de Setup em Infraestrutura & Ambiente; Contas padrão abertas.	**Hardening** repetível e **automação**.
A05: Injeção 	**Manuseio perigoso** de dados externos; **Mistura** de Input & Interpretador.	**Consultas parametrizadas** (**Separar** dado do comando).

Gemini Notebook

O Perfil do Engenheiro Seguro (Boas Práticas Transversais)

A Validação Final é do Servidor

Nunca basear a segurança ou controle de acesso apenas no **Front-end** (JavaScript/Navegador).

Automação de Testes

Incluir verificações de segurança (SAST/DAST) no pipeline de **CI/CD** antes do deploy em produção.

Proteção Contínua de Dados

Utilizar criptografia robusta contra **Ransomware** e nunca transmitir senhas em texto claro.

Defesa em Profundidade

Projetar sistemas protegidos em **camadas**, que sobrevivem mesmo se uma das barreiras falhar.

Gemini Notebook

“O software seguro começa no design.”

Conhecer as táticas de ataque e vulnerabilidades não é sobre hackear, mas sim o primeiro passo fundamental para construir arquiteturas de sistema que não quebram sob pressão.

Referências:
- Dados baseados no projeto OWASP Top 10:2025.
- Diretrizes suportadas pela Cartilha de Segurança para Internet (CERT.br/NIC.br).

Gemini Notebook